Universidad de Jaén
Departamento de Informática

Actividades Tema 1

Introducción y conceptos básicos

Septiembre, 2026

v 1.0

Contenidos

Descripción de las actividades propuestas **1**
Actividad 1.1.- Análisis de seguridad de la cadena de suministro de una aplicación en la nube 1
Actividad 1.2.- Alta y configuración inicial de servicios en un proveedor en la nube 3
Actividad 1.3.- Laboratorio de experimentación en virtualización con contenedores 3
Actividad 1.4.- Estudio de amenazas en la nube 5
Actividad 1.5.- Análisis de noticias de seguridad 6
Anexo I de alta de cuenta para estudiantes en Google Cloud **7**
Anexo II para uso básico del servicio IAM de Google Cloud **9**

Descripción de las actividades propuestas

Importante: revisar el documento sobre normas de realización, entrega y evaluación de las actividades prácticas disponible en la web de la asignatura

Actividad 1.1.- Análisis de seguridad de la cadena de suministro de una aplicación en la nube

En el contexto de seguridad informática, la cadena de suministro de un sistema informático, *supply chain*, hace referencia al conjunto de elementos software o hardware necesarios para su desarrollo y explotación. La seguridad de cada uno de estos elementos puede afectar a la seguridad del sistema final en el que intervienen. Una técnica bastante empleada por los atacantes para comprometer sistemas informáticos consiste en utilizar

vulnerabilidades en bibliotecas o productos software ampliamente utilizados en el desarrollo de aplicaciones. Por este motivo, cuando se acomete el desarrollo de un sistema informático, un aspecto muy importante para garantizar su seguridad en el futuro es realizar un seguimiento de la seguridad de los elementos que compondrán su pila o entorno de desarrollo (*software stack*).

En esta actividad el equipo de trabajo seleccionará una pila o entorno habitual de desarrollo de aplicaciones web o aplicaciones en la nube en general que conozca, esté familiarizado con él o simplemente tenga interés en analizar su seguridad. La **pila o entorno de desarrollo seleccionado deberá contar al menos con**:

- *Sistema operativo* en el que correrá la aplicación
- *Lenguaje de programación* que se empleará
- *Framework/bibliotecas de desarrollo*
- *Motor de base de datos* (relacional/nosql).
- *Proveedor de servicios donde se desplegará la aplicación*

Algunos ejemplos de entornos o elementos específicos podrían ser: L/WAMP (Linux/Windows, Apache httpd, Mysql, PHP/Laravel), MEAN (MongoDB, Express, Angular, Javascript/Node); Linux, Tomcat, Postgres, Java/SpringBoot; Windows Server, SQL Server, C#/DotNet; Linux, MariaDB, Python/Django, etc[1]. Y algunos proveedores: Amazon Web Services, Microsoft Azure, Google Cloud, etc.

Dependiendo del entorno de desarrollo que se escoja, **buscar 1 o 2 recursos específicos en Internet** (webs, foros, redes sociales, listas de distribución, …) donde se pueda estar al día y consultar vulnerabilidades específicas para cada uno de los componentes de la pila de desarrollo, e.g. versiones de cada elemento recomendadas, dónde consultar las últimas vulnerabilidades de ubuntu/linux, apache http, php, symfony, mysql, etc. además de los boletines de seguridad de los servicios de los proveedores de servicios en la nube. También pueden utilizarse algunos de los sitios genéricos de búsqueda de vulnerabilidades disponibles en las diapositivas del tema 1 siempre que permitan la consulta rápida de vulnerabilidades para el recurso en cuestión.

Elaborar un **informe** donde se enumeren los recursos recopilados para el seguimiento de la seguridad de cada elemento del entorno de desarrollo elegido, junto con una descripción breve de lo que se puede encontrar en cada uno de ellos y el/los motivos por los que se han seleccionado. Además, incluir en el informe un apartado donde se **comente alguno de los CVE más recientes** conocidos que afecten a cada uno de los elementos de la pila de desarrollo seleccionada.

Actividad por equipos
Extensión aproximada: 1-2 páginas
Tiempo estimado: 30-60 minutos (**plazo de entrega: 1 de octubre**)

[1] Otros posibles ejemplos de pilas de desarrollo https://en.wikipedia.org/wiki/Solution_stack

Actividad 1.2.- Alta y configuración inicial de servicios en un proveedor en la nube

Darse de alta en un proveedor en al nube y realizar tareas básicas de gestión:

1. Cada estudiante dará de alta su cuenta TIC personal en la UJA (dominio @red.ujaen.es) en **Google Cloud** y **creará una máquina virtual** siguiendo las indicaciones del anexo más abajo.

2. Crear una alerta de presupuesto para el proyecto creado en el punto anterior de forma que el proveedor nos avise si el gasto mensual del proyecto supera una cantidad determinada, e.g. 10$. *Nota: desactivar la opción de descontar crédito para que sepamos realmente el gasto que hay aunque sea con cargo al crédito gratis recibido.*

3. Acceder a la máquina virtual utilizando la consola de SSH y probar a instalar un servidor web básico siguiendo el tutorial Running a basic Apache web server

4. Usando el servicio *Identity Access Manager*, IAM de Google Cloud, dar permisos de acceso al proyecto como propietario (owner) al profesor, jrbalsas@ujaen.es, para supervisión de las actividades o ayudar en caso de necesidad. Otorgar también acceso al proyecto al otro miembro del equipo de trabajo. Para ello, seguir las indicaciones del anexo más abajo.

5. Instalar la App móvil *Cloud Console* de Google y monitorizar algunas métricas de la instancia creada en Google Cloud.

Elaborar un breve **informe** con los pasos más importantes del proceso que se han seguido, añadiendo algunas capturas de pantalla que sirvan para confirmar la consecución de los objetivos o que puedan ser de interés para comprender aspectos importantes del proceso. Indicar expresamente los nombre de los proyectos creados por cada miembro del equipo.

Actividad por equipos
Extensión aproximada: 2 o 4 páginas (principalmente por las capturas de pantalla)
Tiempo estimado: 90 minutos (**plazo de entrega: 1 de octubre**)

Actividad 1.3.- Laboratorio de experimentación en virtualización con contenedores

Instalar el software propuesto para prácticas de la asignatura y realizar algunos experimentos de ejecución en entornos virtualizados:

1. **Instalar en el equipo habitual de trabajo el software para ejecución de contenedores** propuesto en el documento correspondiente de la asignatura.

2. **<u>Cada miembro</u> del equipo de trabajo comprobará su instalación de docker** ejecutando el siguiente comando y aportando al informe la salida del mismo:

   docker run -it --rm macabees/neofetch

3. Realizar **pruebas básicas de control de acceso a recursos sobre máquinas virtuales y contenedores**:

   3.1. En un **sistema linux**[2], instalar php y probar a ejecutar un script simple de php, e.g. *usuario.php*, que muestre el usuario efectivo sobre el que se ejecuta la aplicación. Probar el resultado de ejecuciones tanto con el usuario actual como con el usuario root.
   Notas: utilizar la función passthru de php para ejecutar el comando deseado, e.g. whoami. Usar sudo para ejecutar php como root. PHP dispone de un servidor web básico para probar desde el navegador los scripts ubicados en un directorio, y que puede utilizarse de la siguiente forma:

   ```
   php -S <ip_local>:<puerto> -t <dir>
   ```

   Ejemplo: escuchar en cualquier ip disponible en puerto 8080 y dar acceso a los contenidos del directorio actual

   ```
   php -S 0.0.0.0:8080 -t .
   ```

   Accediendo al script en la url `http://localhost:8080/usuario.php`

   3.2. Ejecutar el script anterior utilizando una versión de php en un **contenedor con docker**[3] [1][2][3] y comprobar algunas opciones para restringir la ejecución

   3.2.1. Ejecución con usuario por defecto[4], e.g.

   ```
   docker run -it --rm --name phptest -v "$(pwd):/app" -w /app php:latest php usuario.php
   ```

   3.2.2. Ejecución como un usuario específico. Utilizar opción -u del comando run de docker[5]

   3.2.3. Ejecución como servidor web (ver apartado 2.1). Utilizar opción -p para exponer el puerto del servidor web de php.

[2] Puede utilizarse WSL2, una máquina virtual sobre virtualbox, la máquina virtual en la nube generada en la actividad 1.3 o incluso desde la Cloud Shell [4]
[3] Pueden lanzarse contenedores docker usando docker desktop o desde Cloud Shell[4]. También puede instalarse docker en una máquina virtual local o la creada en la actividad 1.3
[4] Para indicar la ruta completa del directorio actual en el host que se va a compartir en el contenedor debe utilizarse *$(pwd)* si lanzamos desde una consola Unix o *%cd%* si lanzamos desde una consola windows, e.g. cmd o powershell. Por defecto, en windows o mac docker solo permite que los contenedores tengan a acceso a directorios ubicados en la carpeta del usuario
[5] Los usuarios disponibles en el contenedor pueden consultarse ejecutando el fichero /etc/passwd del propio contenedor, e.g. `docker run -it --rm php:latest cat /etc/passwd`

4. Completar la **creación y despliegue en Cloud Run de un contenedor de prueba**[6] siguiendo los pasos descritos en las diapositivas del seminario de creación y ejecución de contenedores

Elaborar un breve **informe** con los pasos más importantes del proceso que se ha seguido, añadiendo algunas capturas de pantalla que sirvan para confirmar la consecución de los objetivos o que puedan ser de interés para comprender aspectos importantes del proceso.

Actividad por equipos
Extensión aproximada: 2 o 3 páginas (principalmente por las capturas de pantalla)
Tiempo estimado: 120 minutos (**plazo de entrega: 13 de octubre**)

Referencias:

[1] Docker for Beginners. Tutorial interactivo. Tareas 0 y 1.[on-line] Disponible en https://training.play-with-docker.com/beginner-linux
[2] Balsas, J.R. Creación y Ejecución de contenedores [on-line]. UJA, 2026. Disponible en Platea
[3] Docker Tutorial [on-line]. Tutorialspoint. Disponible en https://www.tutorialspoint.com/docker/
[4] Comienza a usar Cloud Shell. Google Cloud Platform. [on-line] Disponible en https://cloud.google.com/shell/docs/launching-cloud-shell

Actividad 1.4.- Estudio de amenazas en la nube

Estudiar y analizar 1 de las siguientes amenazas del informe: Bhatt, A. Brook, J.. et al. *Top Threads to Cloud Computing. CSA, 2026*[7]. La amenaza que cada equipo deberá analizar se asignará por el profeso en el foro de la actividad para garantizar que se cubran al menos las más relevantes:

1. Gestión deficiente de Identidades y Acceso (IAM)
2. Ataques mejorados con IA
3. Recursos de terceros inseguros
4. Interfaces y APIs inseguras
5. Errores en configuración y control de cambios inadecuados
6. Compromiso de sistemas de AI
7. Crimen organizado, Hackers y APT
8. Falta estrategia y gobierno de la seguridad en la nube
9. Desarrollo inseguro de software
10. Divulgación accidental de datos en la nube

[6] Utilizar alguno de los disponibles en el repositorio https://github.com/jrbalsas/asnwebapps, por ejemplo phpwebapp como se indica en las diapositivas del seminario de contenedores de la asignatura
[7] Disponible para **descargar en la web de la asignatura** o también en https://cloudsecurityalliance.org/group/top-threats

11. Vulnerabilidades del sistema

Cada equipo, para la amenaza asignada, realizará una lectura de su descripción en el informe y realizará un resumen ampliado donde se comenten de forma justificada los siguientes aspectos:

- Descripción breve de la amenaza y variantes
- Riesgos STRIDE que podría suponer, justificando, para cada uno de los afectados, en qué sentido se podrían materializar.
- Controles de seguridad recomendados en el informe, según el documento CCM[8] versión 4 de la CSA, que deben implantarse para prevenirlas/mitigarlas. Deben seleccionarse y explicarse al menos los 5 que se consideren más relevantes para cada amenaza.
- Comentar algún caso de ataque real de este tipo de los expuestos en el informe

El **informe** con el análisis de cada una de las amenazas se entregará en un **envío independiente en el *foro de "estudio de amenazas en la nube"*** usando como asunto el número y título de cada amenaza.

Actividad por equipos
Extensión aproximada: 2 páginas (800 palabras) por amenaza
Tiempo estimado: 120 minutos (**plazo de entrega: 8 de octubre**)

Actividad 1.5.- Análisis de noticias de seguridad

Cada estudiante buscará en Internet **dos noticias recientes** y relevantes que estén relacionadas con la seguridad de **aplicaciones o servicios en la nube**[9] y las comentará individualmente, es decir en un envío independiente por noticia, en el **foro específico de "Análisis de noticias de seguridad"** en el espacio de la asignatura. La entrada deberá **incluir al menos** un resumen breve de la noticia, enlace a la fuente original, aspectos importantes de seguridad tratados como: proveedor/servicios/software afectados, tipos de impactos STRIDE, puntuación CVSS (asignada oficialmente o, si se desconoce, calculada de forma aproximada y justificada a partir de las características de explotabilidad e impacto analizados), vulnerabilidades relacionadas y, si se conocen, el CVE, KEV y EPSS, además de al menos *4 controles de seguridad de la propuesta CCM v.4.1 de la CSA*, más relevantes a su criterio, que hubieran ayudado a prevenirlas o mitigarlas justificando brevemente en qué sentido lo conseguirían.

[8] Para comprender el alcance de los diferentes CCM es recomendable utilizar la traducción al español proporcionada en el documento de equivalencias entre los controles CCM y los del ENS, disponible en la web de la asignatura

[9] No se admiten, entre otras, noticias específicas sobre vulnerabilidades en dispositivos móviles, aplicaciones para uso local (e.g. office), navegadores, etc. salvo que dichas vulnerabilidades se hayan utilizado para afectar a servicios ubicados en la nube. Ante la duda, consultar antes con el profesor la viabilidad de la noticia a presentar.

Actividad individual
Extensión aproximada: 400-500 palabras/noticia
Tiempo estimado: 120 minutos
(**plazos de entrega: 1ª noticia, hasta el 15 de octubre; 2ª noticia, hasta el 29 de octubre**)

Anexo I de alta de cuenta para estudiantes en Google Cloud

La Universidad de Jaén dispone de un convenio con Google Cloud para ofrecer a sus estudiantes créditos gratuitos para uso en diferentes recursos de su catálogo de servicios en la nube. Para optar a estos créditos es indispensable utilizar la dirección de correo de los estudiantes en el **dominio @red.ujaen.es** y no será necesario aportar datos para facturación adicionales, como por ejemplo tarjetas de crédito.

Para solicitar estos créditos, debe accederse a través del **siguiente enlace** y **completar el formulario utilizando la dirección de correo de la UJA**[10]. Se recibirá un correo con un enlace para validar la cuenta que deberá activarse. *Si no se recibe el correo es conveniente revisar si no estuviera en la carpeta de correo no deseado (Spam).* A partir de ese momento, se podrá utilizar dicho crédito durante un año o hasta que expire la cantidad asignada.

⚠️ **Si por error asignas el crédito a tu cuenta personal de gmail**, una vez que concluyas el tutorial del anexo actual con dicha cuenta, puedes dar acceso de propietario (*owner*) a tu cuenta de la UJA para el proyecto creado siguiendo las indicaciones del anexo II

Se recomienda utilizar los servicios disponibles con la debida diligencia para evitar agotar los recursos disponibles antes de la finalización del periodo lectivo. Ante cualquier duda, consultar con el profesor sobre la viabilidad de activar o configurar cualquiera de los servicios del catálogo disponible.

Para **dar de alta una máquina virtual de prueba**, seguir los siguientes pasos una vez que se haya confirmado la cuenta de Google Cloud:

1. Acceder a la consola de google cloud https://console.cloud.google.com/ y crear un proyecto para asignarle recursos en la nube, e.g. "*ASN2026-Manuel_Garcia*". IMPORTANTE: asegúrate de que tu nombre aparezca en el nombre del proyecto para que sea fácilmente identificable por el profesor. Ten en cuenta que el proceso puede tardar un breve instante hasta que se haya completado.
2. Cuando el proyecto esté disponible, entrar en el menú de servicios (pulsando en el desplegable situado a la izquierda), y seleccionar la categoría "Compute Engine" dedicada a servicios IaaS para creación de máquinas virtuales

[10] Solo se podrán solicitar los créditos una vez por dirección de correo electrónico

3. Pulsar en crear una instancia de máquina virtual y confeccionar una con las siguientes características para optimizar los costos:
    - Tipo de máquina de e2-medium (preconfigurada con 2vCPU y 4GB de ram) en una región más económica, como us-central1. Apartado de configuración predeterminada.
    - En configuración avanzada, seleccionamos un modelo de aprovisionamiento *estándar* con un límite de tiempo, e.g. 24h (se podrá cambiar más adelante si fuera necesario), y marcamos la opción de *Cerrar la VM de forma ordenada.* Con esta política, la máquina se apagará automáticamente transcurrido ese tiempo, que es suficiente para una sesión de experimentación, con lo que reduciremos los costes de ejecución si se nos olvide apagar la máquina. Comprobar que el coste aproximado estará en torno a los 25 $/mes.
    - Seleccionar una imagen de SO Linux (apartado Disco de arranque, Boot Disk) como Ubuntu 26.04 LTS (para arquitectura x86/64 y opción normal evitando la *mínima*) o cualquier otro si se está más familiarizado con él. También se puede cambiar el tipo de disco por uno de tipo "*Standard persistent disk*" para reducir algo más el coste mensual de la instancia
    - En apartado *Redes,* activar tráfico http y https para que se abran los puertos correspondientes en el cortafuegos
    - Antes de pulsar el botón para crear la máquina es conveniente observar cómo podría llevarse a cabo dicha operación desde la línea de comandos pulsando en el botón "*Equivalent command line*" por si fuera necesario replicar rápidamente la máquina.
    - Se puede consultar el tutorial proporcionado por el proveedor: Quickstart Using a Linux VM, no obstante, tener en cuenta las características de la máquina indicada anteriormente para rebajar al máximo los costes de uso.

Nota: el coste de mantener esta máquina virtual activa durante un mes completo no supera los 25$, por lo que, si el tiempo de ejecución se gestiona adecuadamente, manteniéndola encendida solo durante los periodos en los que se experimente con ella, puede utilizarse para futuras pruebas a lo largo de la asignatura sin que se supere el coste de los créditos asignados.

Anexo II para uso básico del servicio IAM de Google Cloud

El servicio de *Identity Access Management, IAM,* de un proveedor permite gestionar políticas de acceso y asignar usuarios para el acceso a los diferentes servicios gestionados. Los siguientes pasos permite dar acceso a una cuenta de gmail para que pueda entrar a monitorizar el estado de una máquina virtual:

1. **Dar permisos de acceso por defecto al proyecto:**
   1.1. Entrar en IAM y seleccionar el proyecto en cuestión
   1.2. Añadir la cuenta de usuario del **otro integrante del equipo** y asignarle el siguiente rol: Proyecto → Viewer (Acceso de consulta a recursos del proyecto). La cuenta autorizada ya puede encontrar el proyecto en el desplegable (puede tardar un rato, aunque puede introducirse el nombre a mano)
   1.3. Añadir la **cuenta del profesor**, jrbalsas@ujaen.es y asignarle el siguiente rol: Proyecto → Owner (Acceso total a recursos del proyecto). Si has recibido los créditos de Google Cloud con tu cuenta personal de gmail, también puedes dar de alta como owner a tu cuenta TIC de la UJA para poder trabajar con dicha cuenta haciendo uso de los créditos asignados.
2. **Dar permisos sobre una instancia de la VM creada previamente**
   2.1. Seleccionar casilla de la VM en cuestión en instancias de *Compute Engine*
   2.2. A la derecha, en la pestaña de permisos (pulsar en "*show info panel*" si fuera necesario) añadir la cuenta del otro integrante del equipo en cuestión y asignarle los roles correspondientes según los privilegios requeridos. En nuestro caso, al menos: *Compute Engine → Editor*

Referencias:

[1] https://cloud.google.com/compute/docs/access/granting-access-to-resources
[2] Roles en GCE https://cloud.google.com/compute/docs/access/iam